

Vanargand — Modèle de menace v1

Révisions R1 et R2 intégrées.

Le catalogue des attaques connues, adaptées au design de Vanargand, et des zones d'ombre à surveiller. Chaque entrée décrit l'attaque, la parade prévue par Vanargand, et son statut : **résolu par construction, à concevoir** (la parade est identifiée mais pas encore spécifiée), ou **ouvert** (problème difficile, sans solution parfaite connue).

Règle de lecture : une attaque n'est vraiment traitée que si tricher coûte plus cher que d'être honnête, ou si le protocole rend l'attaque grammaticalement impossible.

A. Attaques sur le consensus d'une chaîne

A1. Collusion de validateurs. Si plus d'un tiers des validateurs d'une chaîne (en poids de caution) s'entendent, ils peuvent bloquer la chaîne ; à plus des deux tiers, ils peuvent réécrire son présent. Parade : cautions saisissables, dénonciation inter-chaînes (chapitre D), et surtout le principe de **confiance proportionnée** — les autres chaînes n'acceptent d'une chaîne que des montants de pont proportionnels au total de ses cautions : corrompre une petite chaîne ne rapporte que ce qu'elle a le droit d'exporter. Statut : à concevoir (le barème exact confiance/caution).

A2. Double signature (équivoque). Un validateur signe deux blocs concurrents à la même hauteur pour semer deux vérités. Parade : la fraude produit elle-même sa preuve — deux signatures contradictoires du même validateur, quelques centaines d'octets publiables sur n'importe quelle chaîne ; caution saisie automatiquement, prime au dénonciateur. Statut : résolu par construction.

A3. Attaque longue portée. Des validateurs partis depuis des années utilisent leurs vieilles clés (dont la caution est depuis longtemps retirée) pour réécrire l'histoire depuis un point ancien et fabriquer une fausse chaîne complète. Parade : les **jalons croisés** — l'état de chaque chaîne est régulièrement ancré chez ses voisines ; un nouvel arrivant part du dernier jalon largement co-signé, jamais du bloc d'origine. La fausse histoire ne correspond à aucun jalon reconnu. Statut : résolu par construction, à condition qu'un appareil neuf obtienne ses jalons par plusieurs canaux indépendants (à spécifier).

A4. Manipulation du hasard (grinding). Le hasard des défis et des tirages vient de l'empreinte des blocs — or celui qui fabrique un bloc peut essayer plusieurs variantes et publier celle dont l'empreinte l'arrange (pour éviter d'être contrôlé, ou pour être tiré au sort). C'est une correction au design initial : l'empreinte de bloc seule est une source de hasard biaisable. Parade (R2) : la **chaîne d'engagements scellée à la caution** — au dépôt de caution, chaque validateur committe la racine d'une chaîne d'empreintes, et proposer un bloc, c'est révéler le maillon suivant, qu'il ne peut ni choisir (la chaîne est scellée d'avance) ni cacher sans passer son tour ; l'aléa de l'époque est le mélange des derniers maillons, passé au **VDF** (calcul incompressiblement séquentiel, plus long que la fenêtre de jeu, prouvé en STARK par des prouveurs rémunérés) qui interdit au dernier joueur de tester les variantes. Statut : en spécification (R2) — le VDF-STARK devient le chemin critique du lancement, avec repli documenté (engagement-révélation durci, sans saisie). **La saisie pour non-révélation introduite en R1 est retirée** : panne et rétention produisent le même silence — faute non attribuable, on ne saisit que l'équivoque ; révéler et proposer étant désormais le même geste, le silence retombe sur la sanction douce existante du proposeur muet. Le tirage du comité reste au dernier bloc de l'époque précédente.

A5. Censure de transactions. Les validateurs refusent silencieusement d'inclure les transactions d'une personne ou d'un service. Parade : rotation des proposeurs de blocs à chaque tour, enchère de frais (une transaction censurée augmente ses frais jusqu'à ce qu'un validateur craque), et à terme des listes d'inclusion obligatoires. Statut : partiellement résolu, à approfondir.

A6. Dénier de service sur les validateurs. Saturer les machines des validateurs pour paralyser la chaîne. Parade : frais minimaux sur toute transaction (le spam coûte), rotation et redondance des validateurs, sous-réseaux de secours entre validateurs. Statut : à concevoir (dimensionnement).

A7. État invalide finalisé (ajout R2). Un comité corrompu aux deux tiers peut finaliser un état *invalide* — et les clients légers, qui vérifient signatures et preuves de Merkle mais n'exécutent rien, ne le détecteraient jamais : A3 et B1 parent le fork et l'éclipse, pas la validité. Parade au Cran 1–2 : les **preuves de fraude sur transition d'état** — les types de transaction étant peu nombreux, figés et sans VM, un nœud complet produit une réfutation compacte (les branches de Merkle touchées) qu'un mobile vérifie en millisecondes, diffusée par un canal d'alerte gossip. À l'essai (Cran 2–3) : le **certificat de validité**, un STARK d'époque prouvant non seulement « plus des deux tiers ont signé » mais « ce qu'ils ont signé est valide » — le mobile n'a alors plus à craindre du comité que la censure. Statut : à concevoir en priorité ; contrainte immédiate : tous les types de transaction sont spécifiés « prouvables » (déterminisme strict, aucune dépendance cachée).

B. Attaques sur le réseau de transport

B1. Attaque d'éclipse. Isoler un appareil en devenant tous ses voisins à la fois, pour lui présenter une fausse réalité (faux soldes, fausse chaîne). Parade naturelle de Vanargand : le **multi-transport** — il faut contrôler simultanément l'Internet, le Wi-Fi et le Bluetooth ambiants de la victime, ce qui exige une présence physique ; plus la diversification imposée des pairs et la vérification des jalons multi-sources. Statut : partiellement résolu par l'architecture, règles de sélection de pairs à spécifier.

B2. Partition provoquée. Couper un groupe du monde pour exploiter la coupure. Parade : c'est le scénario nominal de Vanargand — le gossip pour les données et le solde nomade pour l'argent (R1) bornent ex ante ce qu'une partition peut coûter. L'attaquant qui coupe un village n'obtient que des paiements plafonnés aux crédits hors-ligne déclarés d'avance, connus de tous. Statut : résolu par construction.

B3. Sybil sur le pair-à-pair. Inonder le réseau de faux nœuds pour capter le trafic, ralentir le gossip ou espionner. Parade : notation des pairs par comportement, coût de connexion symbolique, et le fait qu'aucun rôle rémunéré n'est accessible sans caution ou sans preuve de travail utile. Statut : à concevoir (paramètres de notation).

B4. Corrélation de trafic. Même chiffré, le trafic a une forme : qui parle, quand, quel volume. Un observateur puissant (opérateur, État) peut relier expéditeurs et destinataires sans rien lire. Parade : rembourrage des tailles de messages, délais aléatoires, routage en oignon optionnel (plusieurs relais dont chacun ne connaît que le précédent et le suivant) — payé en VAN comme le reste. Statut : **ouvert** — aucun système au monde ne le résout parfaitement ; Vanargand doit annoncer honnêtement son niveau de protection et l'améliorer par couches.

C. Attaques économiques

C1. Boucles de primes (wash trading). Faire circuler son propre argent entre ses propres réseaux pour toucher primes de facteur et commissions d'apporteur. Parade : l'invariant central — toute prime provient de frais déjà payés, et une fraction des frais est détruite ; toute boucle fermée perd la fraction détruite à chaque

tour. Statut : résolu par construction ; à surveiller à chaque nouveau flux de prime ajouté au protocole (l'invariant doit être re-vérifié à chaque évolution).

C2. Spam de chaînes fantômes. Enregistrer des milliers de fausses chaînes pour toucher des primes de découvreur. Parade : caution d'enregistrement brûlée si la chaîne reste sans activité réelle ; rémunération du découvreur en pourcentage des frais de pont futurs (une chaîne morte ne rapporte rien). Statut : résolu par construction.

C3. Sybil sur l'amorçage. Créer des millions de faux comptes pour capter les récompenses de bienvenue (une identité Vanargand se crée gratuitement et hors ligne — c'est une propriété voulue, l'attaque est donc garantie si les récompenses sont par tête). Parade : ne jamais récompenser l'inscription, toujours le **travail vérifiable et coûteux** — stocker réellement pendant une durée, relayer, servir de passerelle — avec un budget d'amorçage global décroissant par époque, insensible au nombre de comptes. Statut : résolu par principe, missions à spécifier.

C4. Dumping sur le marché du stockage. Un acteur riche casse les prix, évince les petits stockeurs, puis détient une part dominante des fragments du réseau. Parade : la dispersion imposée des fragments (un contrat de stockage exige des stockeurs distincts en cautions indépendantes), le scellement qui rend chaque copie coûteuse en disque réel, et la possibilité pour tout client d'exiger une diversité minimale. Statut : **ouvert** — reclassé sous C7 (oracle de diversité, R1) ; parade retenue : la diversité est choisie et payée par le client (systèmes autonomes distincts, latences triangulées, cautions indépendantes), jamais garantie par le protocole.

C5. Fermeture frauduleuse de bourse. Deux parties d'une bourse (canal de micro-paiements) : l'une publie un ancien solde qui l'avantage. Parade : fenêtre de contestation à la fermeture — l'autre partie (ou un **guetteur** rémunéré agissant pour elle pendant qu'elle dort) publie le solde plus récent signé, le fraudeur perd sa mise. Statut : résolu par construction, guetteurs à spécifier.

C6. Prise d'otage de fichier. Les stockeurs d'un fichier exigent une rançon pour le rendre. Parade : le codage d'effacement disperse le pouvoir (il faudrait la collusion de la majorité des fragments), la dispersion imposée (C4) rend cette collusion improbable, et le refus de servir est une faute au contrat (caution saisie, fragment reconstruit ailleurs). Statut : résolu par construction si C4 est bien réglé.

C7. L'oracle de diversité (ajout R1). Plusieurs mécanismes reposaient sur la mesure de « clients divers » — or, dans un système où l'identité est gratuite, illimitée et créée hors ligne par conception, mesurer la diversité des identités est le problème de la preuve de personne déguisé : fondamentalement **ouvert**. Parades structurelles (R1) : le multiplicateur de consensus ne se nourrit que de preuves physiques (stockage scellé, participation au consensus), jamais des volumes relais/passerelle ; la diversité des payeurs est pesée au coût (ancienneté × frais déjà brûlés — vieillir un Sybil coûte de vrais VAN partis au feu) ; et toute métrique de diversité doit échouer par sous-estimation du score, jamais par surestimation. À l'essai : l'empreinte de provenance (généalogie des VAN encaissés — un signal, pas une preuve : un acteur riche achète de la diversité au marché) et le client mystère protocolaire (auditeurs cautionnés tirés par l'aléa, qui achètent réellement le service et déposent un reçu signé).

C8. Manipulation du disjoncteur économique (ajout R1). Si la chaîne calcule elle-même le ROI de l'attaquant canonique pour resserrer automatiquement les subventions, ses entrées (agrégats observables) deviennent une cible : forcer le resserrement pour étrangler les subventions des honnêtes est un déni de service économique. Parade : hystérésis, amortissement, bornes de resserrement. Statut : à concevoir — le disjoncteur lui-même est à l'essai.

C9. Fraude canaux × partitions (ajout R1, créditée à la revue externe). Publier la fermeture unilatérale d'une bourse avec un état périmé *dans des blocs provisoires*, pendant que la contrepartie et son guetteur sont de l'autre côté de la coupure : la fenêtre de contestation s'écoule dans un monde où le contestant ne peut pas exister. Danger propre à la combinaison canaux + partitions, qu'aucun des deux domaines ne documente séparément. Parade : liste blanche des types de transaction valides en blocs provisoires (*bourse_close*, *recovery_**, *unbond* grammaticalement interdits) et fenêtres de contestation comptées exclusivement en hauteur de blocs finalisés. Statut : résolu par construction (R1.3).

C10. Fuite de vie privée des preuves de mission (ajout R1). Les timbres joints à un *mission_claim* publient les adresses des payeurs d'un relais — ses clients sont exposés. Parade : sous-adresses à usage unique pour les timbres ; à l'essai : preuve en zéro-connaissance (« k payeurs distincts au-dessus du seuil de provenance ») ne révélant rien d'autre. Statut : résolu par construction (sous-adresses).

D. Attaques sur les ponts et la fédération

D1. Faux quorum distant. Présenter à une chaîne un reçu de sortie signé par de faux validateurs. Parade : le gel enregistre nominativement les clés du quorum distant au moment du départ ; seules ces clés ouvrent la serrure. Statut : résolu par construction.

D2. Vol ou compromission des clés d'un quorum. Les vraies clés des validateurs distants sont volées et signent de faux reçus. Parade : rotation régulière des clés de validateurs, chaque rotation étant annoncée dans les jalons (une signature d'une clé périmée est rejetée) ; fenêtres de contestation qui laissent le temps de crier ; plafonds d'exposition par chaîne (A1). Statut : à concevoir (protocole de rotation).

D3. Rétention de données (le mensonge invisible). Le piège le plus subtil de la fédération : des validateurs signent un jalon mais **ne publient pas les données** qui le sous-tendent. Personne ne peut alors prouver la fraude — on ne peut pas exhiber la contradiction de données qu'on n'a jamais vues. Parade : conditionner la validité d'un jalon à la preuve de publication (échantillonnage de disponibilité : de nombreux appareils tirent au hasard des petits morceaux de l'état et vérifient qu'ils sont bien disponibles). Statut : **ouvert** — c'est un sujet de recherche actif dans toute l'industrie ; Vanargand peut commencer avec des exigences de publication simples et durcir progressivement.

D4. Rejeu inter-chaînes. Représenter la même preuve (gel, sortie) sur deux chaînes ou deux fois sur la même. Parade : identifiant de chaîne dans chaque signature, numéros uniques de gel consommés à l'usage, gel nominatif à destination unique. Statut : résolu par construction.

D5. Éclaireur menteur ou paresseux. Livrer un faux jalon (impossible : les signatures ne se contrefont pas) ou retenir l'information pour la monnayer. Parade à la rétention : la concurrence — n'importe qui peut livrer, le premier encaisse ; retenir un jalon, c'est offrir la prime au suivant. Statut : résolu par construction.

D6. Corruption d'une chaîne entière comme arme. Fonder ou corrompre une chaîne légitime, l'utiliser normalement des mois pour bâtir sa réputation, puis frapper d'un coup (fausse sortie massive). Parade : la confiance proportionnée aux cautions (A1) et aux antécédents plafonne le butin ; la fenêtre de contestation donne aux honnêtes présents sur cette chaîne le temps de dénoncer. Statut : à concevoir (courbe de confiance dans le temps).

E. Attaques sur le stockage

E1. Externalisation. Le stockeur efface les données et, au moment du défi, les redemande en urgence à un autre détenteur. Parade visée : scellement par contrat (chaque copie encodée différemment — la copie du voisin ne répond pas au défi) et délai de réponse court. Statut : **à concevoir** (requalifiée R2) — un scellement réel, lent à produire et rapide à vérifier, est un problème que l'industrie a mis des années et une lourdeur considérable à résoudre ; il n'est pas une brique éprouvée. Au Cran 1, l'archive publique le contourne par le marché de desserte (voir E2).

E2. Attaque de génération. Le stockeur ne garde pas les données mais les *recalcule* à la demande (possible si elles sont compressibles ou dérivables d'une source publique). Parade pour les données privées : fragments chiffrés (incompressibles, indistinguables d'aléa) puis scellés — les régénérer exigerait la clé du propriétaire ; elle dépend donc du scellement (E1). Statut : **à concevoir** (requalifiée R2) pour le privé. Pour l'**archive publique du Cran 1** — le pire cas, régénérable depuis n'importe quel pair — l'attaque est rendue sans objet par changement d'objectif (R2) : on ne paie plus la *détention* mais la **desserte** (défis à réponse chronométrée, triangulation de latence par guetteurs tirés au sort, client mystère qui télécharge réellement et dépose reçu) — un « tricheur » qui sert vite la donnée publique accomplit exactement le service payé, et la diversité récompensée est géographique, mesurée par la vitesse de la lumière : ce marché échappe à C7.

E3. Fausse multiplicité. Prétendre stocker dix copies (dix contrats, dix paiements) sur un seul disque. Parade pour le privé : le scellement rend chaque copie physiquement distincte — dix contrats occupent réellement dix fois l'espace. Statut : **à concevoir** (requalifiée R2, dépend de E1). Pour l'archive publique, la prime de desserte payée à la diversité géographique triangulée rend la multiplicité sur un seul disque sans valeur : un seul point de présence = une seule prime.

E4. Perte corrélée. Tous les fragments d'un fichier atterrissent, via des identités de façade, chez le même acteur ou dans le même centre — une seule panne (ou une seule décision) détruit le fichier malgré le codage d'effacement. C'est la version stockage de C4. Statut : **ouvert** — reclassé sous C7 (oracle de diversité, R1) ; même parade que C4 : la diversité est choisie par le client, le protocole ne la promet pas.

F. Attaques sur la machine virtuelle et les contrats

F1. Bug de contrat (réentrance, débordements, logique). L'histoire des blockchains programmables est jalonnée de contrats vidés par un bug — des centaines de millions perdus ailleurs. Parades : machine virtuelle à exécution déterministe et isolée (WASM), langage de contrat sûr par défaut, les **fonctions vitales du protocole (ponts, gels, preuves de stockage, bourses) implémentées en natif hors VM** — un bug de contrat utilisateur ne peut jamais toucher le cœur —, et le programme permanent de primes aux bugs (chapitre gouvernance). Statut : à concevoir, discipline permanente.

F2. Épuisement de ressources. Un contrat en boucle infinie ou gourmand paralyse les validateurs. Parade : chaque instruction a un prix (le « carburant »), payé d'avance en VAN ; le carburant épuisé, l'exécution s'arrête et l'état est annulé. Statut : résolu par principe, barème à calibrer.

F3. Non-déterminisme. Un contrat dont le résultat varie selon la machine (horloge locale, hasard non contrôlé) fait diverger les validateurs. Parade : la VM n'expose aucune source non déterministe ; l'heure est la hauteur de bloc, le hasard est l'aléa d'époque du protocole. Statut : résolu par construction.

F4. Front-running. Un validateur voit une transaction juteuse en attente et insère la sienne juste avant (achat avant une grosse commande, capture d'une prime de dénonciation). Parade : révélation en deux temps pour les transactions sensibles (on publie d'abord un engagement scellé, puis le contenu), files d'attente équitables. Statut : à concevoir.

G. Attaques de long terme et zones grises

G1. Ordinateur quantique. Menace double : casser les signatures (paré : signatures post-quantiques par défaut) et **décrypter plus tard ce qui est enregistré aujourd'hui** — un adversaire qui archive dès maintenant les messages chiffrés les lira dans vingt ans si l'échange de clés n'est pas lui aussi post-quantique. Parade : chiffrement des contenus par encapsulation post-quantique (ML-KEM) dès la v1, pas seulement les signatures. Statut : à concevoir dès le départ, non reportable.

G2. Capture de la gouvernance. Accumuler assez de poids (cautions, chaînes) pour imposer une mise à jour du protocole qui avantage l'attaquant. Parade : super-majorités élevées, délais d'activation longs (le temps de partir avec ses fonds si on refuse la nouvelle règle), droit de sécession explicite (une chaîne peut quitter la zone VAN plutôt que subir). Statut : à concevoir avec la gouvernance.

G3. Corruption de la chaîne d'approvisionnement logicielle. L'attaque ne vise pas le protocole mais l'application : une mise à jour piégée du logiciel client vole les clés de millions d'utilisateurs. Parade : compilations reproductibles (chacun peut vérifier que le binaire correspond au code source public), signatures multiples des versions, primes aux bugs. Statut : discipline permanente, à outiller.

G4. Attaque sociale sur la récupération de compte. La récupération sociale a son revers : la collusion de vos contacts de confiance (ou leur piégeage par hameçonnage) peut voler votre identité. Parade : seuils élevés, délai de contestation pendant lequel l'ancien appareil peut annuler, notification sur tous les canaux. Statut : à concevoir finement — c'est une attaque contre des humains, pas contre des maths.

G5. Coercition légale ciblée. Un État contraint les validateurs ou passerelles de sa juridiction (censure, saisie, écoute). Parade structurelle : diversité juridictionnelle des validateurs d'une même chaîne, chiffrement qui rend la passerelle aveugle, droit de n'importe qui de monter une chaîne ailleurs. Statut : ouvert par nature — à traiter aussi dans le volet légal.

G6. Les inconnues fabriquées par l'IA. La recherche automatisée de vulnérabilités (fuzzing intelligent, exploration d'états par apprentissage) trouvera dans Vanargand des failles qu'aucune liste humaine n'anticipe. Parade : retourner l'arme — le programme permanent de primes (chapitre gouvernance) paie précisément des machines pour attaquer Vanargand en continu, sur des répliques, avant que d'autres ne le fassent en production. Statut : c'est un processus, pas une case à cocher.

G7. Le risque réglementaire existentiel (ajout R2). L'adversaire le plus probable de l'année 1 n'est ni A1 ni C7 : c'est un courrier de régulateur visant l'entité et les fondateurs. Surface : émission d'un jeton (MiCA — white paper, régimes CASP/PSAN), moyen de paiement lors d'événements physiques (frontière de la monnaie électronique — le cashless des festivals passe par des partenaires agréés), revente de connectivité (ARCEP, CGU des FAI pour les passerelles domestiques), registre public pseudonyme (doctrine CNIL/EDPB : données personnelles, tension immuabilité/effacement), politiques crypto des magasins d'applications. Parades de structure (R2) : fondation porteuse du protocole séparée de la société de développement, conseil spécialisé dès la conception, aucune rampe fiat au lancement, **inversion monétaire du Cran 1** (le VAN ne circule qu'entre machines ; les humains paient en jetons fermés d'organismes déjà régulés), déploiement géo-progressif, et un document compagnon dédié. Statut : ouvert par nature — le seul adversaire de ce catalogue qui se traite chez un avocat, pas dans le code.

Synthèse des chantiers ouverts par ce document

Résolu par construction : A2, A3, B2, C1, C2, C5, C6, C9, C10, D1, D4, D5, F2, F3. À concevoir en priorité : **A4 (aléa — chaîne d'engagements + VDF-STARK, chemin critique du lancement, R2), A7 (preuves de fraude d'état pour les clients légers, R2), E1–E3 (scellement — requalifiées R2, contournées au Cran 1 par le marché de desserte), G1 (chiffrement post-quantique des contenus), A1/D6 (barème de confiance par caution), C8 (disjoncteur économique), D2 (rotation des clés), C3 (missions d'amorçage), F1 (périmètre natif vs VM). Problèmes ouverts, à traiter par couches successives et à annoncer honnêtement : **C7 (oracle de diversité), B4 (corrélation de trafic), D3 (disponibilité des données), G4, G5, G7 (le régulateur — se traite chez un avocat, pas dans le code).****

Ce document doit vivre : chaque nouveau mécanisme ajouté à Vanargand doit passer devant chaque entrée de ce catalogue, et chaque incident du monde des blockchains doit y ajouter sa ligne.